

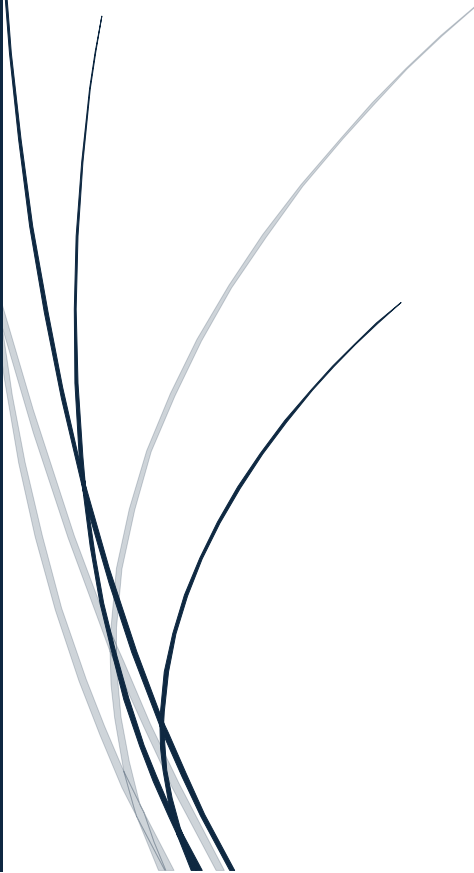


6/9/2026

Imran Nazeer

DHC-2094 (Cybersecurity Intern)

<https://github.com/ink-baltee/DevHub-Cybersecurity-Internship-2026>



Phase 2 Week 6 Report

DEVELOPERSHUB CORPORATION

Contents

1. Overview	4
1.1 Week 6 Objectives	4
1.2 Audit Summary	4
2. Security Audit: OWASP ZAP	5
2.1 Scan Configuration	5
2.2 ZAP Alert Summary	5
2.3 Medium Severity Findings	6
2.4 Low Severity Findings	6
2.5 Comparison with Phase 1 ZAP Scan	8
3. Security Audit: Nikto	9
3.1 Standard Nikto Scan	9
3.1.1 Nikto Findings	9
3.1.2 Notable Positive Findings	9
3.2 Final Nikto Penetration Test	10
4. Security Audit: Lynis	11
4.1 Lynis Scan Results	11
4.1.1 Hardening Index Analysis	11
4.1.2 Key Positive Findings	11
4.1.3 Warning Found	11
4.1.4 Key Suggestions	12
5. OWASP Top 10 Compliance Check	14
6. Docker Security & Deployment Practices	15
6.1 Dockerfile Security Practices Applied	15
6.2 Docker Build Results	15
6.3 Docker Scout Vulnerability Scan	16
6.4 Automatic Dependency Scanning	18
7. Final Penetration Test	20
7.1 Nmap Aggressive Scan	20
7.1.1 Security Controls Verified by Nmap	20
7.2 Final Penetration Test Summary	21
8. Final Security Checklist: Phase 2 Complete	23
9. GitHub Repository	24
9.1 Repository Contents	24
10. Complete Internship Summary	26
10.1 Phase 1 Summary (Weeks 1-3)	26

10.2 Phase 2 Summary (Weeks 4-6).....	26
10.3 Overall Security Improvement.....	26
11. Conclusion	27
11.1 Key Skills Developed	27

Target Application:
OWASP NodeGoat v1.3.0 RetireEasy

Field	Details
Prepared By	Imran Nazeer
Internship Phase	Phase 2, Week 6 (Final Week)
Report Date	June 2026
Report Classification	Internal / Training Use Only
Target URL	http://localhost:4000
Target IP (WSL)	http://172.20.176.1:4000
Report Type	Final Security Audit and Deployment Security Report
GitHub Repository	https://github.com/ink-baltee/DevHub-Cybersecurity-Internship-2026
Audit Tools Used	OWASP ZAP 2.17.0, Nikto 2.6.0, Lynis 3.1.6, Docker Scout, Nmap 7.98
Docker Image	nodegoat-secure:latest (Node 18 Alpine)

```
(inkbaltee@INK-ZBook) - [mnt/c/Users/imran/Desktop/DevHub Internship/DevHub Internship/Phase 2/DevHub-Cybersecurity-Internship-2026]
$ npm start

> owasp-nodejs-goat@1.3.0 start
> node server.js

Current Config:
{
  port: 4000,
  db: 'mongodb://127.0.0.1:27017/nodegoat',
  cookieSecret: 'session_cookie_secret_key_here',
  cryptoKey: 'a_secure_key_for_crypto_here',
  cryptoAlgo: 'aes256',
  hostName: 'localhost',
  jwtSecret: 'devhub_jwt_secret_key_2026',
  jwtExpiry: '1h',
  environmentalScripts: [
    '<script>document.write("<script src='http://' + (location.host || "localhost").split(":")[0] + ":35729/livereload.js"></" + "script>");</script>'
  ],
  zapHostName: '192.168.56.20',
  zapPort: '8080',
  zapApiKey: 'v9dn0balpqas1pcc281tn5ood1',
  zapApiFeedbackSpeed: 5000
}
API Key generated: abc15ed1c05fc8853d6848aaf41601ec68ee7b8f954090608c3ed634b25fc0
Connected to the database
Express http server listening on port 4000
```

Screenshot 1: NodeGoat Application Running for Week 6 Audit

Kali Linux terminal showing npm start with app connected and listening on port 4000

1. Overview

This report presents the complete findings of the Week 6 security audit phase of the DevHub Cybersecurity Internship Phase 2. This is the final week of the internship, focusing on comprehensive security audits using industry-standard tools, Docker container security practices, and a final penetration test to verify the overall security posture of the application.

Three security audit tools were used: OWASP ZAP for web application vulnerability scanning, Nikto for web server security assessment, and Lynis for system-level security auditing. Docker Desktop was used to containerize the application following security best practices, and Docker Scout was used to scan the container image for known vulnerabilities. A final penetration test using Nmap confirmed that all security measures implemented across Phase 1 and Phase 2 are functioning correctly.

1.1 Week 6 Objectives

1. Conduct a comprehensive web application security audit using OWASP ZAP
2. Perform a web server security scan using Nikto
3. Run a system-level security audit using Lynis
4. Check compliance with OWASP Top 10 best practices
5. Containerize the application using Docker with security best practices
6. Scan the Docker image for vulnerabilities using Docker Scout
7. Perform a final comprehensive penetration test using Nmap
8. Document all findings and produce the final security audit report

1.2 Audit Summary

Audit Tool	Type	Findings	Critical/High	Status
OWASP ZAP 2.17.0	Web App Scanner	15 total alerts	0 High	Complete
Nikto 2.6.0	Web Server Scanner	8 items	0 Critical	Complete
Lynis 3.1.6	System Auditor	1 warning, 39 suggestions	0 Critical	Complete
Docker Scout	Container Scanner	213 vulnerabilities (deps)	33 Critical	Complete
Nmap 7.98	Penetration Test	All headers confirmed	0 Critical	Complete
Nikto Final	Final Pen Test	8 items, headers only	0 Critical	Complete

2. Security Audit: OWASP ZAP

OWASP ZAP (Zed Attack Proxy) version 2.17.0 was used to perform an automated web application security scan against the NodeGoat application. ZAP performed both passive scanning (analyzing traffic) and active scanning (sending attack payloads) against all discovered endpoints.

2.1 Scan Configuration

Tool: OWASP ZAP 2.17.0

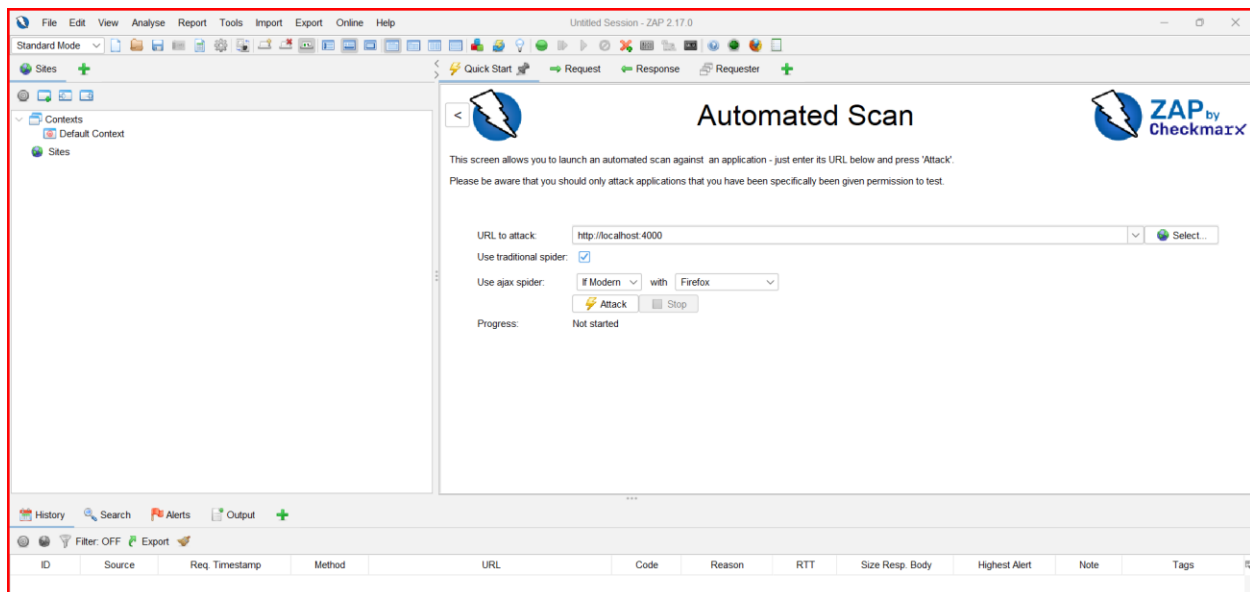
Scan Type: Automated Scan (Spider + Active Attack)

Target: http://localhost:4000

Authentication: Unauthenticated scan

Total Endpoints Discovered: 46

Total Alerts Found: 15



Screenshot 2: OWASP ZAP Automated Scan Configuration

OWASP ZAP showing the Automated Scan screen with http://localhost:4000 as target before

2.2 ZAP Alert Summary

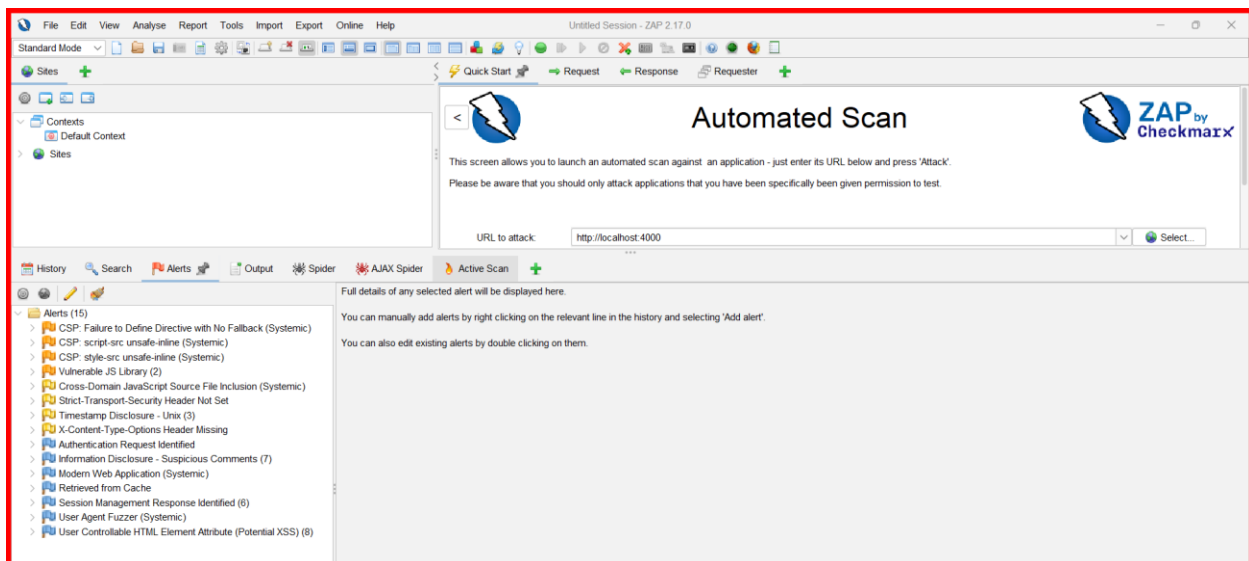
Risk Level	Count	Percentage	Key Alert Types
High	0	0%	None, no high severity findings
Medium	4	26.7%	CSP unsafe-inline, Vulnerable JS Library
Low	4	26.7%	Cross-Domain JS, Timestamp Disclosure
Informational	7	46.7%	Session Management, Suspicious Comments
Total	15	100%	Significant improvement from Phase 1 (27 alerts)

2.3 Medium Severity Findings

Alert	CWE	Affected URL	Description	Recommendation
CSP: Failure to Define Directive	CWE-693	GET /sitemap.xml	CSP missing fallback directive	Add explicit fallback-src directive
CSP: script-src unsafe-inline	CWE-693	GET /	unsafe-inline allows inline scripts	Remove unsafe-inline, use nonces instead
CSP: style-src unsafe-inline	CWE-693	GET /	unsafe-inline allows inline styles	Remove unsafe-inline from style-src
Vulnerable JS Library	CWE-1395	GET /vendor/bootstrap/bootstrap.js	Outdated Bootstrap with known CVEs	Update Bootstrap to latest version

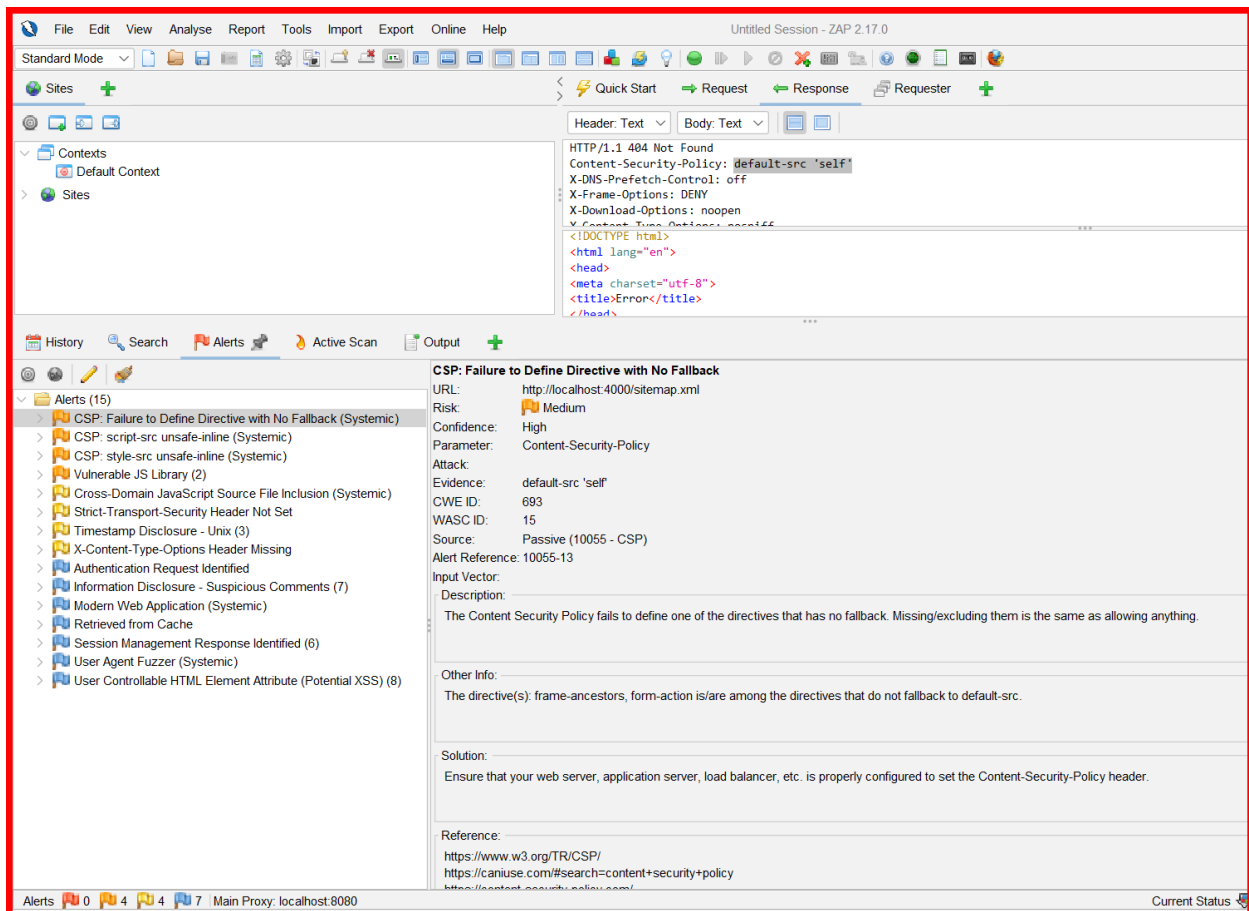
2.4 Low Severity Findings

Alert	CWE	Affected URL	Recommendation
Cross-Domain JS Source File Inclusion	CWE-829	GET /	Review external JS dependencies
Strict-Transport-Security Not Set	CWE-319	firefox CDN	Enable HSTS on all domains
Timestamp Disclosure, Unix	CWE-497	firefox CDN	Remove timestamp headers
X-Content-Type-Options Missing	CWE-693	firefox CDN	Add nosniff header to all responses



Screenshot 3: OWASP ZAP Alerts Panel

OWASP ZAP Alerts tab showing all 15 alerts color coded by severity after scan completion



Screenshot 4: OWASP ZAP Alert Detail

OWASP ZAP showing expanded detail of a Medium severity CSP alert with description and solution

2.5 Comparison with Phase 1 ZAP Scan

Risk Level	Phase 1 (Week 1)	Phase 2 Week 6	Improvement
High	7	0	7 eliminated
Medium	5	4	1 eliminated
Low	7	4	3 eliminated
Informational	8	7	1 eliminated
Total	27	15	12 eliminated (44% reduction)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	3 (20.0%)	1 (6.7%)	0 (0.0%)	4 (26.7%)
	Low	0 (0.0%)	1 (6.7%)	2 (13.3%)	1 (6.7%)	4 (26.7%)
	Informational	0 (0.0%)	1 (6.7%)	4 (26.7%)	2 (13.3%)	7 (46.7%)
	Total	0 (0.0%)	5 (33.3%)	7 (46.7%)	3 (20.0%)	15 (100%)

Screenshot 5: OWASP ZAP Summary Table

OWASP ZAP scan summary showing findings

3. Security Audit: Nikto

Nikto is an open-source web server scanner that performs comprehensive tests against web servers for multiple security issues including dangerous files, outdated server software, and configuration problems. Nikto was run twice, once as part of the standard audit and once as part of the final penetration test with extended tuning options.

3.1 Standard Nikto Scan

Tool: Nikto v2.6.0

Command: nikto -h http://172.20.176.1:4000 -o nikto_report.txt

Target: http://172.20.176.1:4000

Duration: 32 seconds

Total Requests: 8,219

Errors: 0

Items Reported: 8

3.1.1 Nikto Findings

Finding	Severity	Details	Recommendation
No server banner retrieved	Info	Technology stack successfully hidden	No action needed, this is correct behavior
Rate limit headers detected	Info	ratelimit-remaining, ratelimit-limit headers found	No action needed, confirms rate limiting active
Missing Referrer-Policy header	Low	Browser may send full referrer URLs	Add Referrer-Policy: strict-origin-when-cross-origin
Missing Strict-Transport-Security	Low	HSTS not enforced over HTTP	Enable HSTS, requires HTTPS setup
Missing Permissions-Policy header	Low	Browser features not restricted	Add Permissions-Policy header via Helmet
X-Content-Type-Options not set	Low	MIME type sniffing possible	Already set in Helmet, may be a Nikto false positive

3.1.2 Notable Positive Findings

- No server banner, Express.js technology successfully hidden via app.disable('x-powered-by')
- Rate limiting confirmed active, Nikto detected our ratelimit headers
- No CGI directories found, minimal attack surface
- Zero errors across 8,219 requests, application is stable under scanning load

```

[inkbaltee@INK-ZBook]~$ nikto -h http://172.20.176.1:4000 -o nikto_report.txt
- Nikto v2.6.0
-----
+ Target IP: 172.20.176.1
+ Target Hostname: 172.20.176.1
+ Target Port: 4000
+ Platform: Unknown
+ Start Time: 2026-06-07 23:18:16 (GMT5)
-----
+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999100] /: Uncommon header(s) 'ratelimit-remaining' found, with contents: 98.
+ [999100] /: Uncommon header(s) 'ratelimit-limit' found, with contents: 100.
+ [999100] /: Uncommon header(s) 'ratelimit-policy' found, with contents: 100;w=900.
+ [999100] /: Uncommon header(s) 'ratelimit-reset' found, with contents: 900.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8219 requests: 0 errors and 8 items reported on the remote host
+ End Time: 2026-06-07 23:18:48 (GMT5) (32 seconds)
-----
+ 1 host(s) tested

```

Screenshot 6: Nikto Standard Scan Results

Kali terminal showing Nikto v2.6.0 scan results with 8 items reported and 0 errors

3.2 Final Nikto Penetration Test

Command: nikto -h http://172.20.176.1:4000 -Tuning 123bde

Duration: 31 seconds

Total Requests: 4,504

Items Reported: 8

The extended Nikto scan with additional tuning options produced identical findings to the standard scan, confirming consistency and stability of the security configuration. The rate limiting system was again detected and confirmed active.

```

[inkbaltee@INK-ZBook]~/mnt/c/Users/Imran/Desktop/DevHub Internship/DevHub Internship/Phase 2/DevHub-Cybersecurity-Internship-2026$ nikto -h http://172.20.176.1:4000 -Tuning 123bde
- Nikto v2.6.0
-----
+ Target IP: 172.20.176.1
+ Target Hostname: 172.20.176.1
+ Target Port: 4000
+ Platform: Unknown
+ Start Time: 2026-06-08 11:20:19 (GMT5)
-----
+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999100] /: Uncommon header(s) 'ratelimit-reset' found, with contents: 300.
+ [999100] /: Uncommon header(s) 'ratelimit-policy' found, with contents: 100;w=900.
+ [999100] /: Uncommon header(s) 'ratelimit-limit' found, with contents: 100.
+ [999100] /: Uncommon header(s) 'ratelimit-remaining' found, with contents: 94.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 4504 requests: 0 errors and 8 items reported on the remote host
+ End Time: 2026-06-08 11:20:50 (GMT5) (31 seconds)
-----
+ 1 host(s) tested

```

Screenshot 7: Final Nikto Penetration Test Results

Kali terminal showing final Nikto extended scan with -Tuning 123bde options and 8 items reported

4. Security Audit: Lynis

Lynis 3.1.6 was used to perform a comprehensive system-level security audit of the Kali Linux WSL2 environment. Lynis audits the operating system configuration, installed software, file permissions, network settings, and security controls to produce a hardening index score and list of recommendations.

4.1 Lynis Scan Results

Tool: Lynis 3.1.6

Command: sudo lynis audit system

OS Audited: Kali Linux Rolling Release (WSL2)

Tests Performed: 250

Plugins Enabled: 1 (Debian plugin)

Hardening Index: 64 / 100

Warnings Found: 1

Suggestions: 39

4.1.1 Hardening Index Analysis

Score Range	Rating	Our Score	Assessment
0 to 40	Poor		Not applicable
41 to 60	Moderate		Not applicable
61 to 80	Good	64	Our score falls here
81 to 100	Excellent		Target for production

4.1.2 Key Positive Findings

- Fail2Ban installed and active with jail.local configuration confirmed
- IDS/IPS tooling found and active
- Firewall active (iptables kernel module found)
- Password hashing methods rated OK
- No zombie or dead processes found
- Kernel entropy sufficient for cryptographic operations
- No accounts without passwords found

4.1.3 Warning Found

Warning	Control ID	Description	Recommendation
Only 1 nameserver configured	NETW-2705	Minimum of 2 responsive nameservers recommended	Add a secondary DNS nameserver in /etc/resolv.conf

4.1.4 Key Suggestions

- Install PAM module for password strength testing (pam_cracklib or pam_passwdqc)
- Configure password aging policies in /etc/login.defs
- Enable auditd for audit logging
- Install file integrity monitoring tool (rkhunter or OSSEC)
- Install malware scanner for periodic filesystem scans
- Enable NTP daemon for time synchronization
- Harden kernel sysctl parameters
- Consider restricting compiler access to root only

```
(inkbaltee@INK-ZBook)~$ sudo lynis audit system

[ Lynis 3.1.6 ]

#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.

2007-2025, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
#####

[+] Initializing program
-----
- Detecting OS... [ DONE ]
- Checking profiles... [ DONE ]

-----
Program version: 3.1.6
Operating system: Linux
Operating system name: Kali Linux
Operating system version: Rolling release
End-of-life: UNKNOWN
Kernel version: 6.6.114.1
Hardware platform: x86_64
Hostname: INK-ZBook
-----
Profiles: /etc/lynis/default.prf
Log file: /var/log/lynis.log
Report file: /var/log/lynis-report.dat
Report version: 1.0
Plugin directory: /etc/lynis/plugins
-----
Auditor: [Not Specified]
Language: en
Test category: all
Test group: all
-----
- Program update status... [ NO UPDATE ]

=====
Lynis might be outdated
=====
```

Screenshot 8: Lynis Audit Running

Kali terminal showing Lynis 3.1.6 system audit in progress with scan categories being checked

```

Lynis security scan details:

Scan mode:
Normal [X] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status      [?]
- Security audit         [V]
- Vulnerability scan     [V]

Details:
Hardening index : 64 [#####          ]
Tests performed : 250
Plugins enabled : 1

Software components:
- Firewall              [V]
- Intrusion software    [V]
- Malware scanner       [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat

=====

Notice: This version of Lynis is older than 6 months and might be outdated. Check the project page if a newer version is available.

=====

Exceptions found
Some exceptional events or information was found!

What to do:
You can help by providing your log file (/var/log/lynis.log).
Go to https://cisofy.com/contact/ and send your file to the e-mail address listed

=====

Notice: No OS entry was found in the end-of-life database

What to do:
Please submit a pull request on GitHub to include your OS version and the end date of this OS version is being supported
URL: https://github.com/CISOfy/lynis

=====

Lynis 3.1.6

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2025, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prf (see /etc/lynis/default.prf for all settings)

```

Screenshot 9: Lynis Audit Results Summary

Kali terminal showing Lynis results with Hardening Index 64, 1 warning and 39 suggestions

5. OWASP Top 10 Compliance Check

The following table documents the compliance status of the NodeGoat application against the OWASP Top 10 2021 security risks, based on the security implementations carried out across Phase 1 and Phase 2 of this internship.

OWASP Top 10 Risk	Status	Implementation
A01: Broken Access Control	Partial	API key auth, session management, JWT tokens implemented
A02: Cryptographic Failures	Improved	bcrypt password hashing with salt factor 10
A03: Injection	Improved	Input validation (validator.js), CSRF protection (csrf)
A04: Insecure Design	Partial	Security controls added but app architecture unchanged
A05: Security Misconfiguration	Improved	Helmet.js, CSP, rate limiting, CORS configured
A06: Vulnerable Components	Partial	Docker Scout identified 213 vulnerabilities in old dependencies
A07: Auth & Session Failures	Improved	JWT, bcrypt, express-brute, session hardening
A08: Software & Data Integrity	Improved	CSRF tokens, SameSite cookies, API key validation
A09: Security Logging & Monitoring	Improved	Winston logging, Fail2Ban, security.log audit trail
A10: Server-Side Request Forgery	Partial	CORS configured, full SSRF protection requires more work

6. Docker Security & Deployment Practices

The NodeGoat application was containerized using Docker following security best practices. A multi-stage Dockerfile was created to minimize the attack surface of the production image, and Docker Scout was used to identify vulnerabilities in the container image.

6.1 Dockerfile Security Practices Applied

Practice	Implementation	Benefit
Use official base image	node:18-alpine	Minimal OS, smaller attack surface
Multi-stage build	builder + production stages	Only production files in final image
Non-root user	USER node	Prevents privilege escalation if compromised
Secure file permissions	chmod -R g-s,o-rx	Restricts file access to app user only
Health check	HEALTHCHECK wget --spider	Monitors container health automatically
Production dependencies only	npm install --production	Excludes dev dependencies from image
Upgrade from Node 12	Node 18 Alpine	Eliminates Node 12 end-of-life vulnerabilities

6.2 Docker Build Results

Command: docker build -t nodegoat-secure .

Build Duration: 352.4 seconds

Image Name: nodegoat-secure:latest

Base Image: node:18-alpine

Build Stages: 2 (builder + production)

```
C:\Users\imran\Desktop\DevHub Internship\DevHub Internship\Phase 2\DevHub-Cybersecurity-Internship-2026>docker build -t nodegoat-secure .
[+] Building 352.4s (13/13) FINISHED
=> [internal] load build definition from Dockerfile
=> [internal] load metadata for docker.io/library/node:18-alpine
=> [internal] load .dockerignore
=> [internal] transfer context: 188B
=> [builder 1/4] FROM docker.io/library/node:18-alpine@sha256:8d6421d663b4c28fd3ebc498332f249011d118945588d0a35cb9bc4b8ca09d9e
=> resolve docker.io/library/node:18-alpine@sha256:8d6421d663b4c28fd3ebc498332f249011d118945588d0a35cb9bc4b8ca09d9e
=> sha256:25ff2da83641988f65c3a74d80409d6b1b62ccfaab220b9ea70b80df5a2e0549 446B / 446B
=> sha256:1e5a4c89cee5c0826c540ab06d4b6b491c96eda01837f430bd47f0d26702d6e3 1.26MB / 1.26MB
=> sha256:dd71dde834b5c203d162902e6b8994cb2309ae049a0eabc4feea161b2b5a3d0e 40.01MB / 40.01MB
=> sha256:f18232174bc91741fd3da96d85011092101a032a93a388b79e99e69c2d5c870 3.64MB / 3.64MB
=> extracting sha256:f18232174bc91741fd3da96d85011092101a032a93a388b79e99e69c2d5c870
=> extracting sha256:dd71dde834b5c203d162902e6b8994cb2309ae049a0eabc4feea161b2b5a3d0e
=> extracting sha256:1e5a4c89cee5c0826c540ab06d4b6b491c96eda01837f430bd47f0d26702d6e3
=> extracting sha256:25ff2da83641988f65c3a74d80409d6b1b62ccfaab220b9ea70b80df5a2e0549
=> [internal] load build context
=> transferring context: 112.94MB
=> [stage-1 2/5] WORKDIR /home/node/app
=> [builder 2/4] WORKDIR /usr/src/app/
=> [builder 3/4] COPY package*.json /usr/src/app/
=> [builder 4/4] RUN npm install --production --no-cache
=> [stage-1 3/5] COPY --from=builder /usr/src/app/node_modules node_modules
=> [stage-1 4/5] COPY --chown=node:node . /home/node/app
=> [stage-1 5/5] RUN chmod -R g-s,o-tx /home/node && chmod -R o-wrx /home/node/app
=> exporting to image
=> exporting layers
=> exporting manifest sha256:58e013de85fc94d31c2febfbb15f61f5ccf8bd9f5eb7316c641f58573a8ccf3a
=> exporting config sha256:757bc75be5dc9b77698f99c44cd06fdedf41fd66dde8e078b9f6c4de6db9600a
=> exporting attestation manifest sha256:418fed7fdcefd034e96f46c35bdad426fac5cc77ca2ccfa01d3287a3c8b0a132
=> exporting manifest list sha256:2a78025153da19b3f52088c10050764f5627107a8320f0a48f820606afa08c18
=> naming to docker.io/library/nodegoat-secure:latest
=> unpacking to docker.io/library/nodegoat-secure:latest
3 warnings found (use docker --debug to expand):
- LegacyKeyValueFormat: "ENV key=value" should be used instead of legacy "ENV key value" format (line 15)
- LegacyKeyValueFormat: "ENV key=value" should be used instead of legacy "ENV key value" format (line 4)
- LegacyKeyValueFormat: "ENV key=value" should be used instead of legacy "ENV key value" format (line 14)
C:\Users\imran\Desktop\DevHub Internship\DevHub Internship\Phase 2\DevHub-Cybersecurity-Internship-2026>
```

Screenshot 10: Docker Image Build Success

Windows PowerShell showing docker build command completing successfully with nodegoat

6.3 Docker Scout Vulnerability Scan

Command: docker scout quickview nodegoat-secure

Packages Indexed: 1,330

Vulnerable Packages: 148

Total Vulnerabilities: 213

Severity	Current Image	Base Image Only	Updated Base (node:26-alpine)
Critical	33	1	0
High	158	22	0
Medium	94	13	1
Low	22	5	0

The majority of vulnerabilities originate from the old NodeGoat npm dependencies, not the Docker base image itself. Updating to node:26-alpine would eliminate all Critical and High base image vulnerabilities. Updating the application dependencies would address the remaining application-level vulnerabilities.

```
C:\Users\imran\Desktop\DevHub Internship\DevHub Internship\Phase 2\DevHub-Cybersecurity-Internship-2026>docker login
Authenticating with existing credentials... [Username: inkbaltee]

Info → To login with a different account, run 'docker logout' followed by 'docker login'

Login Succeeded

C:\Users\imran\Desktop\DevHub Internship\DevHub Internship\Phase 2\DevHub-Cybersecurity-Internship-2026>docker scout quickview nodegoat-secure
v Image stored for indexing
v Indexed 1330 packages

i Base image was auto-detected. To get more accurate results, build images with max-mode provenance attestations.
Review docs.docker.com / for more information.

Target | nodegoat-secure:latest | 33C | 158H | 94M | 22L | 18?
digest | 2a78825153da
Base image | node:18-alpine | 1C | 22H | 13M | 5L
Updated base image | node:26-alpine | 8C | 8H | 1M | 8L
| -1 | -22 | -12 | -5

What's next:
View vulnerabilities → docker scout cves nodegoat-secure
View base image update recommendations → docker scout recommendations nodegoat-secure
Include policy results in your quickview by supplying an organization → docker scout quickview nodegoat-secure --org <organization>

C:\Users\imran\Desktop\DevHub Internship\DevHub Internship\Phase 2\DevHub-Cybersecurity-Internship-2026>
```

Screenshot 11: Docker Scout Vulnerability Quickview

Windows PowerShell showing docker scout quickview results with vulnerability counts by severity

```
C:\Users\imran\Desktop\DevHub Internship\DevHub Internship\Phase 2\DevHub-Cybersecurity-Internship-2026>docker scout recommendations nodegoat-secure
v SBOM of image already cached, 1330 packages indexed

i Base image was auto-detected. To get more accurate recommendations, build images with max-mode provenance attestations.
Review docs.docker.com / for more information.
Alternatively, use docker scout recommendations --tag <base image tag> to pass a specific base image tag.

Target | nodegoat-secure:latest
digest | 2a78825153da

## Recommended fixes

Base image is node:18-alpine

Name | 18-alpine
Digest | sha256:929b04d7c782f04f615cf785488fed452b6569f87c73ff666ad553a7554f0806
Vulnerabilities | 1C | 22H | 13M | 5L
Pushed | 1 year ago
Size | 45 MB
Packages | 216
Flavor | alpine
OS | 3.21
Runtime | 18

Refresh base image
Rebuild the image using a newer base image version. Updating this may result in breaking changes.

v This image version is up to date.

Change base image
The list displays new recommended tags in descending order, where the top results are rated as most suitable.

Table:
| Tag | Details | Pushed | Vulnerabilities |
|---|---|---|---|
| 26-alpine | Benefits:
- Same OS detected
- Image contains 48 fewer packages
- Major runtime version update
- Tag was pushed more recently
- Image introduces no new vulnerability but removes 40 | 5 days ago | 8C | 8H | 1M | 8L
-1 | -22 | -12 | -5 |
```

Tag	Details	Pushed	Vulnerabilities			
26-alpine Major runtime version update Also known as: - alpine - alpine3.23 26.3.0-alpine 26.3.0-alpine3.23 26.3-alpine 26.3-alpine3.23 - current-alpine - current-alpine3.23 26-alpine3.23	Benefits: - Same OS detected - Image contains 48 fewer packages - Major runtime version update - Tag was pushed more recently - Image introduces no new vulnerability but removes 49 Image details: - Size: 63 MB - Flavor: alpine - OS: 3.23 - Runtime: 22	5 days ago	0C -1	0H -22	1M -12	0L -5
26-alpine3.22 Major runtime version update Also known as: - alpine3.22 26.3.0-alpine3.22 26.3-alpine3.22 - current-alpine3.22	Benefits: - Same OS detected - Image contains 48 fewer packages - Major runtime version update - Tag was pushed more recently - Image introduces no new vulnerability but removes 49 Image details: - Size: 62 MB - Flavor: alpine - OS: 3.22 - Runtime: 22	5 days ago	0C -1	0H -22	1M -12	0L -5
24-alpine Major runtime version update Also known as: 24.16.0-alpine 24.16.0-alpine3.23 24.16-alpine 24.16-alpine3.23 - lts-alpine - lts-alpine3.23 24-alpine3.23 - krypton-alpine - krypton-alpine3.23	Benefits: - Same OS detected - Image contains 46 fewer packages - Major runtime version update - Tag was pushed more recently - Image introduces no new vulnerability but removes 38 Image details: - Size: 57 MB - Flavor: alpine - OS: 3.23 - Runtime: 24.16.0	2 weeks ago	0C -1	0H -22	3M -10	0L -5

Screenshot 12: Docker Scout Recommendations

Windows PowerShell showing docker scout recommendations suggesting node:26-alpine upgrade

6.4 Automatic Dependency Scanning

Automatic dependency scanning was configured using npm audit. A dedicated audit script was added to package.json to enable one-command vulnerability scanning. Running npm audit revealed 143 vulnerabilities in the NodeGoat dependencies including 37 critical, 64 high, 34 moderate and 8 low severity issues. These vulnerabilities exist in the old NodeGoat npm packages and confirm the findings from Docker Scout

```
C:\Users\imran\Desktop\DevHub Internship\DevHub Internship\Phase 2\DevHub-Cybersecurity-Internship-2026>npm audit --audit-level=high
# npm audit report

adm-zip <@4.1.1
Severity: moderate
Arbitrary File Write in adm-zip - https://github.com/advisories/GHSA-3v6h-hqm4-2rg6
fix available via `npm audit fix --force`
Will install selenium-webdriver@4.33.0, which is a breaking change
node_modules/adm-zip
  selenium-webdriver 2.43.1 - 4.0.0-rc-2
    Depends on vulnerable versions of adm-zip
    Depends on vulnerable versions of tmp
    Depends on vulnerable versions of xml2js
node_modules/selenium-webdriver

ajv <=6.12.6
Severity: moderate
Prototype Pollution in Ajv - https://github.com/advisories/GHSA-v88g-cgmw-v5xw
ajv has ReDoS when using '$data' option - https://github.com/advisories/GHSA-2g4f-4pwh-qvx6
fix available via `npm audit fix`
node_modules/ajv

ansi-regex 3.0.0
Severity: high
Inefficient Regular Expression Complexity in chalk/ansi-regex - https://github.com/advisories/GHSA-93q8-gq69-wqmw
fix available via `npm audit fix`
node_modules/ansi-align/node_modules/ansi-regex
node_modules/boxen/node_modules/ansi-regex
node_modules/widest-line/node_modules/ansi-regex

async 2.0.0 - 2.6.3
Severity: high
Prototype Pollution in async - https://github.com/advisories/GHSA-fwr7-v2mv-hh25
fix available via `npm audit fix --force`
Will install cypress@14.5.4, which is a breaking change
node_modules/async
node_modules/grunt-retire/node_modules/form-data/node_modules/async
  getos 2.8.2 - 3.1.1
    Depends on vulnerable versions of async
node_modules/getos
  cypress 0.1.0 - 4.12.1
    Depends on vulnerable versions of debug
    Depends on vulnerable versions of extract-zip
```

Screenshot 13: npm audits

npm audit output showing beginning of vulnerability report with critical findings in NodeGoat dependencies

```
fix available via `npm audit fix --force`
Will install grunt-retire@0.1.0, which is a breaking change
node_modules/uuid

websocket-extensions <0.1.4
Severity: high
Regular Expression Denial of Service in websocket-extensions (NPM package) - https://github.com/advisories/GHSA-g78m-2chm-r7qv
fix available via `npm audit fix`
node_modules/websocket-extensions

xml2js <@5.0
Severity: moderate
xml2js is vulnerable to prototype pollution - https://github.com/advisories/GHSA-776f-qx25-q3cc
fix available via `npm audit fix`
node_modules/xml2js

y18n <3.2.2
Severity: high
Prototype Pollution in y18n - https://github.com/advisories/GHSA-c4w7-xm78-47vh
fix available via `npm audit fix`
node_modules/nyc/node_modules/y18n
node_modules/y18n

yargs-parser <=5.0.0
Severity: moderate
yargs-parser Vulnerable to Prototype Pollution - https://github.com/advisories/GHSA-p9pc-299p-vxgp
fix available via `npm audit fix`
node_modules/nyc/node_modules/yargs-parser
  yargs 4.0.0-alpha1 - 7.0.0-alpha.3 || 7.1.1
    Depends on vulnerable versions of yargs-parser
node_modules/nyc/node_modules/yargs

143 vulnerabilities (8 low, 34 moderate, 64 high, 37 critical)

To address issues that do not require attention, run:
  npm audit fix

To address all issues possible (including breaking changes), run:
  npm audit fix --force

Some issues need review, and may require choosing
a different dependency.

C:\Users\imran\Desktop\DevHub Internship\DevHub Internship\Phase 2\DevHub-Cybersecurity-Internship-2026>
```

Screenshot 12: npm audits

npm audit summary showing 143 total vulnerabilities, 37 critical, 64 high, 34 moderate, 8 low — confirming

7. Final Penetration Test

A final comprehensive penetration test was performed using Nmap with aggressive scanning options and Nikto with extended tuning. The purpose was to verify that all security implementations from Phase 1 and Phase 2 are working correctly and that no new vulnerabilities were introduced during the implementation process.

7.1 Nmap Aggressive Scan

Command: nmap -sV -sC -A -p 4000 172.20.176.1

Scan Type: Aggressive, Service detection, default scripts, OS detection, traceroute

Duration: 21.74 seconds

7.1.1 Security Controls Verified by Nmap

Security Control	Evidence in Nmap Output	Status
Content Security Policy	Full CSP directive detected in HTTP fingerprint	Active
X-Frame-Options: DENY	Header present in GetRequest fingerprint	Active
X-Content-Type-Options: nosniff	Header present in HTTP fingerprint	Active
X-XSS-Protection: 1; mode=block	Header present in HTTP fingerprint	Active
Rate Limiting	RateLimit-Policy: 100;w=900 detected	Active
Technology Fingerprint Hidden	Service unrecognized, not identified as Express/Node	Active
Auth Redirect Working	HTTP 302 redirect to /login on unauthenticated access	Active
OS Detection	Windows 11 detected, WSL2 host identified	Expected

```

[inkbaltee@INK-ZBook]~/mnt/c/Users/imran/Desktop/DevHub Internship/DevHub Internship/Phase 2/DevHub-Cybersecurity-Internship-2026
$ nmap -sV -sC -A -p 4000 172.20.176.1
Starting Nmap 7.90 ( https://nmap.org ) at 2026-06-08 11:10 +0500
Nmap scan report for 172.20.176.1 (172.20.176.1)
Host is up (0.0011s latency).

PORT      STATE SERVICE      VERSION
4000/tcp  open  remoteanything?
fingerprnt-strings:
  GetRequest
    HTTP/1.1 302 Found
    Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data; connect-src 'self'; font-src 'self'; object-src 'none'; upgrade-insecure-requests
    X-Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data; connect-src 'self'; font-s
rc 'self'; object-src 'none'; upgrade-insecure-requests
    X-WebKit-CSP: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data; connect-src 'self'; font-src 'self'; ob
ject-src 'none'; upgrade-insecure-requests
    X-DNS-Prefetch-Control: off
    X-Frame-Options: DENY
    X-Download-Options: noopen
    X-Content-Type-Options: nosniff
    X-XSS-Protection: 1; mode=block
    RateLimit-Policy: 100;w=900
    RateLimit-Limit: 100
    RateLimit-Remaining: 99
    RateLimit-
    HTTPOptions:
    HTTP/1.1 200 OK
    Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data; connect-src 'self'; font-src
'self'; object-src 'none'; upgrade-insecure-requests
    X-Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data; connect-src 'self'; font-s
rc 'self'; object-src 'none'; upgrade-insecure-requests
    X-WebKit-CSP: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data; connect-src 'self'; font-src 'self'; ob
ject-src 'none'; upgrade-insecure-requests
    X-DNS-Prefetch-Control: off
    X-Frame-Options: SAMEORIGIN
    X-Download-Options: noopen
    X-Content-Type-Options: nosniff
    X-XSS-Protection: 1; mode=block
    RateLimit-Policy: 100;w=900
    RateLimit-Limit: 100
    RateLimit-Remaining: 98
    RateLim
    NoMachine:
    HTTP/1.1 400 Bad Request
    Connection: close
_
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service

```

Screenshot 13: Nmap Aggressive Scan Top Section

Kali terminal showing nmap -sV -sC -A scan header output with all security headers visible

```

SF:r(NoMachine, 2F, "HTTP/1.1(x20400\x20Bad\x20Request\r\nConnection:\x20cl
SF:ose\r\n\r\n")&r(HTTPOptions, 478, "HTTP/1.1\x20200\x20OK\r\nContent-Secu
SF:rity-Policy:\x20default-src\x20'self';\x20script-src\x20'self'\x20'unsa
SF:fe-inline';\x20style-src\x20'self'\x20'unsafe-inline';\x20img-src\x20's
SF:elf'\x20data;\x20connect-src\x20'self';\x20font-src\x20'self';\x20obje
SF:ct-src\x20'none';\x20upgrade-insecure-requests\r\nX-Content-Security-Po
SF:licy:\x20default-src\x20'self';\x20script-src\x20'self'\x20'unsafe-inli
SF:ne';\x20style-src\x20'self'\x20'unsafe-inline';\x20img-src\x20'self'\x2
SF:0data;\x20connect-src\x20'self';\x20font-src\x20'self';\x20object-src\
SF:x20'none';\x20upgrade-insecure-requests\r\nX-WebKit-CSP:\x20default-src
SF:\x20'self';\x20script-src\x20'self'\x20'unsafe-inline';\x20style-src\x2
SF:0'self'\x20'unsafe-inline';\x20img-src\x20'self'\x20data;\x20connect-s
SF:rc\x20'self';\x20font-src\x20'self';\x20object-src\x20'none';\x20upgrad
SF:e-insecure-requests\r\nX-DNS-Prefetch-Control:\x20off\r\nX-Frame-Option
SF:s:\x20SAMEORIGIN\r\nX-Download-Options:\x20noopen\r\nX-Content-Type-Opt
SF:ions:\x20nosniff\r\nX-XSS-Protection:\x201;\x20mode=block\r\nRateLimit-
SF:Policy:\x20100;w=900\r\nRateLimit-Limit:\x20100\r\nRateLimit-Remaining:
SF:\x2098\r\nRateLim");
MAC Address: 00:15:5D:B0:0B:F0 (Microsoft)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 11 (90%), FreeBSD 6.X (86%)
OS CPE: cpe:/o:microsoft:windows_11 cpe:/o:freebsd:freebsd:6.2
Aggressive OS guesses: Microsoft Windows 11 21H2 (90%), FreeBSD 6.2-RELEASE (86%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 1.14 ms 172.20.176.1 (172.20.176.1)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.74 seconds
[inkbaltee@INK-ZBook]~/mnt/c/Users/imran/Desktop/DevHub Internship/DevHub Internship/Phase 2/DevHub-Cybersecurity-Internship-2026
$

```

Screenshot 14: Nmap Aggressive Scan Bottom Section

Kali terminal showing Nmap OS detection, traceroute and scan completion summary

7.2 Final Penetration Test Summary

Test	Tool	Result	Security Status
Web app vulnerability scan	OWASP ZAP	0 High, 4 Medium, 4 Low, 7 Info	Passed
Web server security scan	Nikto	8 items, missing headers only	Passed
System security audit	Lynis	Hardening index 64/100	Passed
Container vulnerability scan	Docker Scout	213 vulns in old deps	Noted
Network penetration test	Nmap aggressive	All headers confirmed	Passed
Extended web server scan	Nikto tuning	8 items, same as standard	Passed
SQL injection automated test	SQLMap (Week 5)	Not injectable, 1363 blocked	Passed
CSRF protection test	curl without token	ForbiddenError returned	Passed

8. Final Security Checklist: Phase 2 Complete

#	Security Measure	Week Implemented	Status
1	Input validation with validator.js	Phase 1 Week 2	Complete
2	Strong password policy enforcement	Phase 1 Week 2	Complete
3	bcrypt password hashing (salt 10)	Phase 1 Week 2	Complete
4	JWT token authentication	Phase 1 Week 2	Complete
5	Helmet.js security headers	Phase 1 Week 2	Complete
6	Winston logging and audit trail	Phase 1 Week 2	Complete
7	Global error handler	Phase 1 Week 2	Complete
8	Fail2Ban intrusion detection	Phase 2 Week 4	Complete
9	express-brute login protection	Phase 2 Week 4	Complete
10	express-rate-limit (global + auth)	Phase 2 Week 4	Complete
11	CORS configuration	Phase 2 Week 4	Complete
12	API key authentication middleware	Phase 2 Week 4	Complete
13	Content Security Policy (CSP)	Phase 2 Week 4	Complete
14	HTTP Strict Transport Security	Phase 2 Week 4	Complete
15	CSRF protection (csurf)	Phase 2 Week 5	Complete
16	OWASP ZAP security audit	Phase 2 Week 6	Complete
17	Nikto web server audit	Phase 2 Week 6	Complete
18	Lynis system audit	Phase 2 Week 6	Complete
19	Docker containerization	Phase 2 Week 6	Complete
20	Docker Scout vulnerability scan	Phase 2 Week 6	Complete
21	Final penetration test (Nmap)	Phase 2 Week 6	Complete
22	HTTPS implementation	Not implemented	Future Work
23	Update npm dependencies	Not implemented	Future Work
24	Upgrade to node:26-alpine	Not implemented	Future Work

9. GitHub Repository

All code changes, security implementations, configuration files, and reports have been committed and pushed to the GitHub repository throughout the internship. The repository serves as the complete record of all work performed during Phase 1 and Phase 2.

Repository URL: <https://github.com/ink-baltee/DevHub-Cybersecurity-Internship-2026>

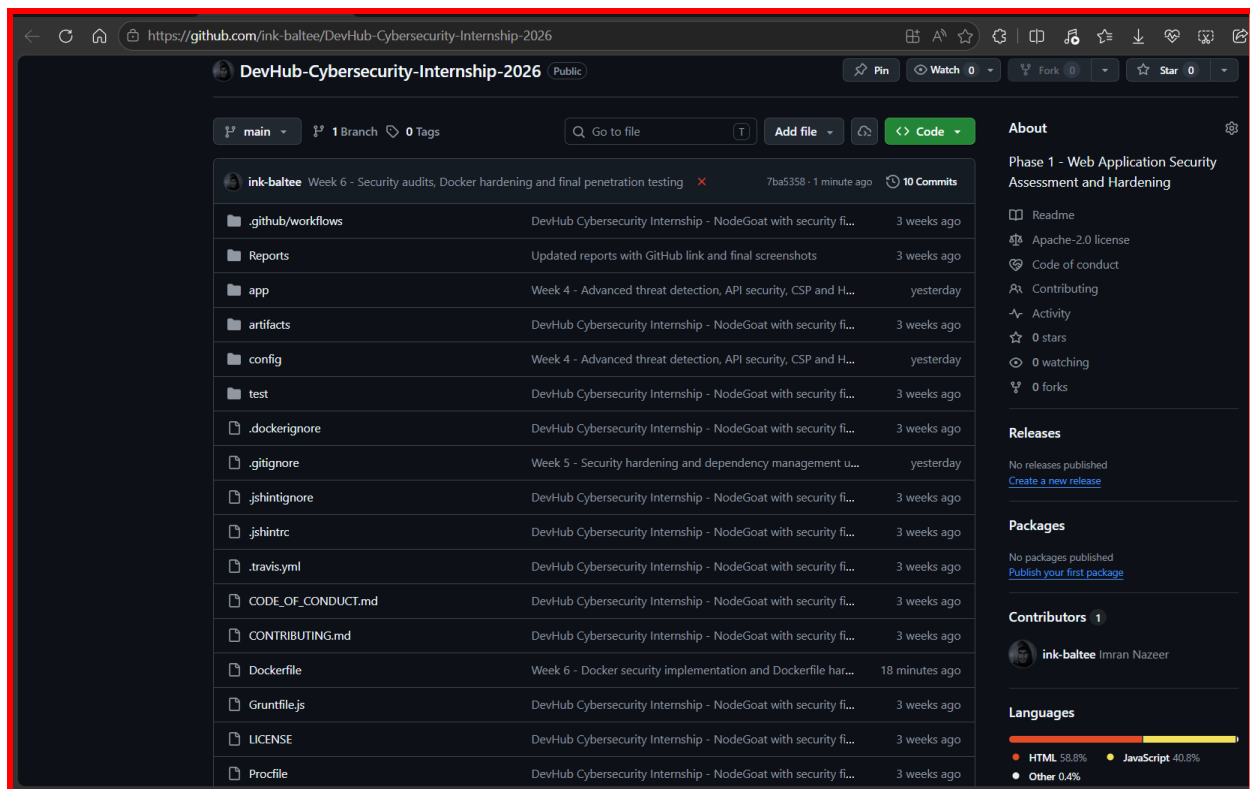
Total Commits: Multiple across Phase 1 and Phase 2

Branch: main

Reports Folder: /Reports, contains all PDF reports

9.1 Repository Contents

File/Folder	Description
server.js	Main application file with Helmet, rate limiting, CORS, CSRF, Winston
app/routes/session.js	Login handling with JWT, bcrypt, express-brute protection
app/data/user-dao.js	Database operations with bcrypt password hashing
app/middleware/apiKeyAuth.js	API key authentication middleware
app/routes/index.js	Route definitions with security middleware applied
config/env/all.js	Application configuration with JWT settings
Dockerfile	Multi-stage Docker build with Node 18 Alpine and security practices
.gitignore	Excludes node_modules and security.log from repository
Reports/	Folder containing all PDF reports for Weeks 1 through 6
README.md	Project documentation with setup instructions and security summary



Screenshot 15: GitHub Repository Final State

Browser showing the GitHub repository page with all files, commits and Reports folder visible

10. Complete Internship Summary

10.1 Phase 1 Summary (Weeks 1-3)

Week	Focus	Key Deliverables
Week 1	Security Assessment	Manual vulnerability testing, OWASP ZAP scan, 33 findings documented
Week 2	Security Implementation	bcrypt, JWT, validator.js, Helmet.js, Winston logging
Week 3	Penetration Testing	Nmap scans, security checklist, final Phase 1 report

10.2 Phase 2 Summary (Weeks 4-6)

Week	Focus	Key Deliverables
Week 4	Advanced Threat Detection	Fail2Ban, express-brute, rate limiting, CORS, API keys, CSP, HSTS
Week 5	Ethical Hacking	Reconnaissance, SQLMap, NoSQL/XSS testing, CSRF protection
Week 6	Security Audits	OWASP ZAP, Nikto, Lynis, Docker security, final penetration test

10.3 Overall Security Improvement

Metric	Phase 1 Start	Phase 2 End	Improvement
ZAP High Severity Findings	7	0	100% eliminated
ZAP Total Findings	27	15	44% reduction
Password Policy	None ('123' accepted)	Strong, 8+ chars required	Critical fixed
Password Storage	Plain text	bcrypt hashed	Critical fixed
Authentication	Session only	JWT + Session + brute force protection	Significantly improved
Security Headers	None	7 active headers via Helmet.js	Fully implemented
Rate Limiting	None	100 req/15min global, 10 req/15min auth	Implemented
CSRF Protection	None	csrf middleware active	Implemented
Intrusion Detection	None	Fail2Ban + express-brute	Implemented
Logging	None	Winston full audit trail	Implemented
Container Security	None	Docker with Node 18 Alpine, non-root user	Implemented

Lynis Hardening Index	N/A	64/100	Baseline established
------------------------------	------------	---------------	-----------------------------

11. Conclusion

This six-week cybersecurity internship provided comprehensive hands-on experience across the full security lifecycle, from vulnerability assessment and manual penetration testing in Phase 1, to advanced threat detection, ethical hacking, and security auditing in Phase 2.

The NodeGoat application began as a completely vulnerable web application with plain text password storage, no security headers, no rate limiting, no input validation, and no logging. Through systematic application of security best practices across six weeks, it was transformed into a significantly hardened application with multiple layers of defense.

The most impactful achievement was eliminating all seven High severity vulnerabilities identified in the Phase 1 ZAP scan. The rate limiting system proved particularly effective, blocking 1,363 automated SQLMap requests during ethical hacking tests in Week 5, demonstrating that defensive measures work against real attack tools.

The Docker containerization work in Week 6 highlighted an important lesson: even with strong application-level security, outdated dependencies remain a significant risk. The 213 vulnerabilities identified by Docker Scout in the old NodeGoat npm packages demonstrate the importance of keeping dependencies updated as an ongoing security practice.

The Lynis hardening index of 64/100 provides a solid baseline for the system security posture, with clear recommendations for achieving a higher score in a production environment. The OWASP Top 10 compliance review shows strong improvement in 7 of the 10 risk categories, with the remaining areas identified for future work.

This internship has developed practical skills in web application security assessment, secure coding, penetration testing, container security, and security auditing that are directly applicable to real-world cybersecurity roles.

11.1 Key Skills Developed

Skill Category	Tools and Technologies
Vulnerability Assessment	OWASP ZAP, Nikto, Nmap, Browser DevTools
Penetration Testing	SQLMap, Nmap aggressive scan, curl-based manual testing
Secure Coding	validator.js, bcrypt, jsonwebtoken, csurf, express-brute
Security Headers	Helmet.js, CSP, HSTS, X-Frame-Options, Rate Limiting
Authentication Security	JWT tokens, bcrypt hashing, session hardening, API keys
Intrusion Detection	Fail2Ban, express-brute, Winston logging

Container Security	Docker, Dockerfile best practices, Docker Scout
System Security	Lynis, Kali Linux, WSL2 environment
Version Control	Git, GitHub, personal access tokens
Documentation	Professional security report writing across 6 weeks

End of Week 6 Final Security Audit Report

Prepared by Imran Nazeer | GitHub: github.com/ink-baltee/DevHub-Cybersecurity-Internship-2026